[CHALLENGE FICTIF] Helios Energy : investigation CTI

Incident INC-2026-0302 : de l'artefact au rapport

- Victime fictive ; indicateurs en plages de documentation (RFC 5737) et domaines .test
- Soutenance : 20 minutes + 10 minutes de questions
- Équipe, rôles et temps passé : **non communiqués** ; toutes les opérations ont eu lieu le 2026-10-06
- Principe : OBSERVÉ / CORROBORÉ / HYPOTHÈSE / INCONNU / NON TESTÉ

Mission et dossier reçu

Annoncé	Reçu	Écart
40 IoC	40, 0 doublon	RFC 5737, .test
12 alertes	12, toutes dans le journal	alerte 5 hors séquence
3 binaires	**3 fiches, 0 échantillon**	pas d'analyse statique
mémo	1, daté du 2 mars	décrit des faits des 5 à 7 mars
journal brut	372 lignes (12 utiles)	bruit d'une seule journée

Objectif : analyse indépendante, plateformes, STIX, détections testées, rapports. La victime est Helios ; on étudie l'attaquant.

Méthode et garde-fous

- Originaux jamais modifiés (sha256 relus) ; inventaires par script
- **29 preuves relues automatiquement** dans les originaux
- Techniques ATT&CK reconstruites puis vérifiées sur attack.mitre.org (v19, publiée le 28 avril 2026 ; v18.1 en vigueur lors de l'incident)
- Aucune valeur d'IoC envoyée à un tiers ; aucun binaire manipulé
- Production protégée : enrichissement automatique tiers et flux Jira identifiés avant toute écriture ; marquage TLP:RED comme garde ; aucun domaine créé en observable
- Cotation Admiralty : fiabilité de la source et crédibilité de l'information séparées

Qualité des données : 21 incohérences, jamais « corrigées »

- **I-03** : `svc-backup-temp` ouvre une session RDP le 4 mars, mais est créé le 5 mars (36 h plus tard)
- **I-02** : mémo daté du 2 mars décrivant les 5 à 7 mars
- **I-04, I-05** : source du RDP interne ou externe ; IP publique source d'un balayage interne
- **I-18** : parent winword.exe pour un classeur .xlsm
- **I-19** : « tentative » d'effacement alors que 1102 atteste l'effacement

Chaque anomalie : plusieurs lectures possibles (HYP-001 à 012) avec leur impact. Aucune n'est présentée comme erreur certaine.

Chronologie : des bornes d'observation

UTC	Observation
03-02 08:31	winword.exe lance powershell -enc … -w hidden
03-02 08:42	GET 200 d'un exécutable de 421 376 octets
03-02 08:46	tâche MicrosoftEdgeUpdateTaskMachine créée
03-03 10:13	balayage 445/3389 de 10.20.0.0/16
03-04 01:48	RDP par svc-backup-temp sur srv-fichiers-02
03-04 11:05	thread distant dans explorer.exe
03-05 14:07–14:12	accès LSASS 0x1010 ; compte créé sur dc-01
03-05 15:31	2 469 135 790 octets vers 203.0.113.28:8080
03-07 09:02	journal Security effacé

2 mars 08:31 et 7 mars 09:02 = première et dernière observation du dossier, pas début et fin de l'intrusion.

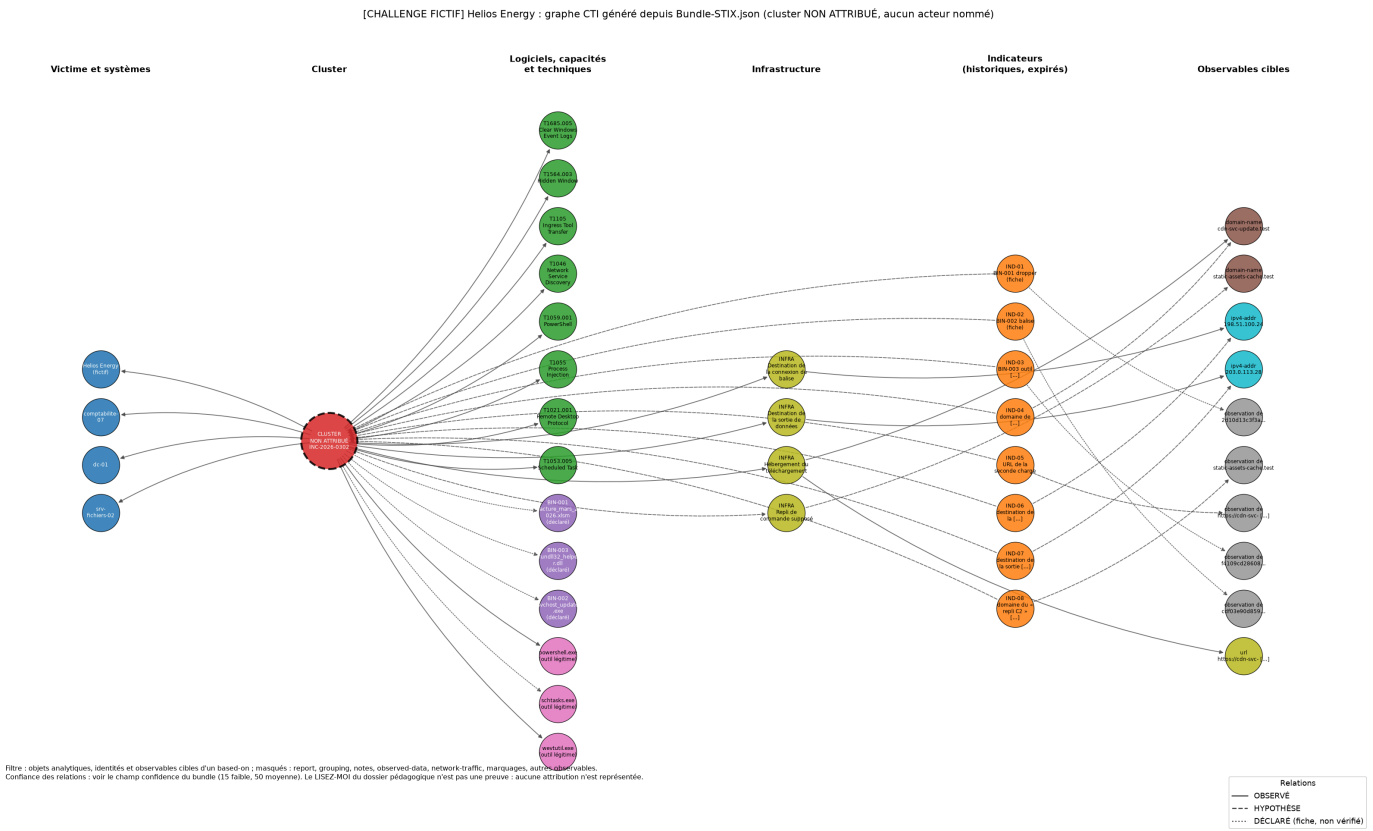
12 alertes : ce que chaque ligne démontre

- Pas de reprise des techniques du SIEM : 10 retenues après examen, **2 écartées**
- **Alerte 8** : T1055.012 (hollowing) contesté ; la ligne est `CreateRemoteThread into explorer.exe RWX region` : injection par thread distant, T1055 au niveau parent ; sous-technique, auteur et lien avec BIN-002 non démontrés
- **Alerte 9** : T1543.003 (service) écarté : 4720 est une création de compte (T1136.002 probable)
- **Alerte 12** : T1070.001 est devenu **T1685.005** en ATT&CK v19 (28 avril 2026 ; T1070.001 en v18.1) (le validateur Sigma a signalé l'ancien identifiant)
- Alerte 4 : **une seule** connexion de balise : la périodicité de 300 s n'est pas mesurable

Fiches binaires : « analyse des fiches fournies »

- Aucun échantillon : **aucun hash recalculé**, aucun binaire exécuté ou désassemblé
- BIN-001 : PowerShell encodé observé ; macro déclarée
- BIN-002 : taille 421 376 = journal (corroboré, non indépendant) ; hollowing, balise 300 s ± 20 %, chiffrement : **non démontrés**
- BIN-003 : accès LSASS observé ; outil « très largement partagé » selon la fiche ; service Windows non démontré

Graphe CTI (généré depuis le bundle STIX)



Trait plein : observé ; tirets : hypothèse ; pointillés : déclaré. Cluster non attribué, aucun acteur nommé. Filtre documenté.

Attribution : cluster non attribué

- Aucune observation discriminante ; **aucune source indépendante**
- La piste du LISEZ-MOI : indication du dossier pédagogique, **pas une preuve** (elle répète la fiche BIN-02)
- HYP-A1 (outillage recoupant une famille connue) : faible ; HYP-A3 (État) : non soutenue
- Confiance : « non attribuable » **élevée** ; « finalité lucrative » faible (non discriminante)
- Biais surveillés : confirmation, notoriété, sélection, ancrage sectoriel

MISP, OpenCTI, STIX : ce qui existe réellement et comment

Plateforme	Méthode réelle d'import	Ce qui existe (relu par API et interface, 06 et 07/10)
MISP	API REST, utilisateur Publisher dédié ; organisation créée par **INSERT SQL direct** (exception, non recommandée)	événement 6, distribution 0, 46 attributs, 5 objets, 8 galaxies, 0 corrélation
OpenCTI 6.9.21	API GraphQL (scripts idempotents) ; **ni connecteur MISP, ni import du bundle**	1 rapport + 3 notes ; 1 incident, 4 données observées, 4 détections ; 27 observables, 8 indicateurs ; 1 enquête ; 5 RFI ouvertes
Wazuh	2 fichiers ajoutés ; logtest isolé, logtest production, rejeu API	27 alertes (règles 130101 à 130115)
STIX 2.1	dérivé de l'export MISP ; non importé	152 objets, 0 erreur de validation ; 27 objets de renseignement liés (méthode conservatrice, 25 sans les 2 ajouts les plus faibles)

TheHive et Cortex : non utilisés, vérifiés en lecture seule. Réserve : onglet Indicateurs de l'incident vide.

Détection : 15 règles Sigma, 7 niveaux de test

- 11 règles DIRECTES, 3 IOC, 1 CHASSE (ne prouve rien seule)
- Syntaxe pySigma : 15/15 ; conversion SQLite ; **0 écart sur 410 événements** (jeux synthétiques écrits par l'équipe : aucun taux de production)
- Wazuh : adaptations manuelles ; **logtest 26/45, puis 40/45, puis 45/45** : trois passes, deux corrections des décodeurs ; rejeu isolé 27/27 alertes ; **production : 27 alertes générées, 27 documents dans l'indexeur**, 0 pour les 18 négatifs
- Dashboard Wazuh : 27 alertes vues le 2026-10-06

Rejeu en production : précautions

- Deux fichiers nouveaux, validation `analysisd -t`, redémarrage de 41 s
- Niveaux 4 à 7 : sous le seuil 10 de l'intégration TheHive et le niveau 12 d'e-mail ; aucune règle d'AR ne vise ces identifiants
- Rejeu limité (3) puis complet (42) ; 0 intégration, 0 réponse active
- Identification : groupe helios_challenge, règles 130101 à 130115, location API-Webhook
- Retour arrière documenté (suppression des 2 fichiers)

Impact, risques, recommandations

Actif	Observé	Potentiel
comptabilite-07	exécution, tâche, effacement de journal	identifiants, rebond
srv-fichiers-02	RDP, injection (indice)	données métier
dc-01	accès LSASS, compte, 2,47 Go sortis	annuaire, tout le SI

- Aucun annuaire compromis ni système industriel affirmé : non démontrés
- P0 : chasse de persistance, isolement et image de comptabilite-07 ; P1 : qualifier les données sorties, filtrer le trafic en clair ; P2 : journaux protégés, segmentation

Réglementation et partage

- OIV/SIIV : notification à l'ANSSI **sans délai** (L1332-6-2), **si** OIV et SIIV touché : conditionnel ici
- NIS 2 : transposition non achevée d'après l'ANSSI (mars 2026) ; aucun délai applicable en l'état
- RGPD : 72 h CNIL **si** violation de données personnelles : contenu inconnu
- TLP 2.0 (FIRST) : RED, AMBER+STRICT, AMBER, GREEN, CLEAR ; WHITE supprimé
- Rien n'est partagé ; aucune déclaration réelle

Limites et exigences non satisfaites

- 0 échantillon ; 1 ligne de balise ; journal Security effacé ; aucune source indépendante
- Graphe de connaissance sur le rapport (pas d'écran graphe pour l'incident) ; MISP : étiquettes personnalisées non créées ; TLP AMBER (MISP) ≠ RED (OpenCTI)
- 25 objets liés : 27 démontrés sous une méthode propre à l'équipe (définition non confirmée) ; dépôt Git non créé ; équipe et temps non communiqués
- Aucune exigence n'est relue par le commanditaire : 33 exigences officielles sur 36 sont satisfaites et contrôlées (voir la clôture)

Écoresponsabilité : infrastructure existante réutilisée, conteneur de test supprimé ; **aucune économie chiffrée** (non mesurée).